

Testes de Cripto feitos pelo chat

Perguntas de Verdadeiro ou Falso:

Verdadeiro ou Falso:

- 1) O CVE (Common Vulnerabilities and Exposures) é um sistema utilizado para medir o impacto financeiro das vulnerabilidades de segurança.

Verdadeiro ou Falso:

- 2) A estrutura de Feistel utilizada no DES realiza múltiplas iterações de substituição e permutação para garantir difusão e confusão.

Verdadeiro ou Falso:

- 3) O Diffie-Hellman é um protocolo assimétrico que permite o compartilhamento seguro de uma chave secreta, mesmo sem autenticação prévia entre as partes.

Verdadeiro ou Falso:

- 4) Em criptografia de curvas elípticas, chaves menores fornecem o mesmo nível de segurança que chaves maiores no RSA.

Verdadeiro ou Falso:

- 5) O modo CBC (Cipher Block Chaining) do AES é considerado mais seguro que o modo ECB porque introduz aleatoriedade com o uso de um vetor de inicialização (IV).

Verdadeiro ou Falso:

- 6) Um ataque de força bruta contra um algoritmo criptográfico é facilitado quando a chave utilizada tem comprimento maior que 128 bits.

Correção das Perguntas de Verdadeiro ou Falso:

1) Falso ☒

Justificação correta: O CVE identifica vulnerabilidades, mas não mede impactos financeiros. O CVSS faz essa análise de severidade.

Correto.

2) Verdadeiro ☒

Justificação correta: A estrutura de Feistel realiza substituição e permutação em várias rodadas, garantindo difusão e confusão.

Correto.

3) Verdadeiro ☒

Justificação correta: O Diffie-Hellman permite o compartilhamento seguro de uma chave secreta sem canal seguro, mas sem autenticação prévia.

Correto.

4) Verdadeiro ☒

Justificação correta: Em criptografia de curvas elípticas, chaves menores (e.g., 256 bits) oferecem a mesma segurança que chaves RSA maiores (e.g., 2048 bits).

Correto.

5) Verdadeiro ☒

Justificação correta: O modo CBC usa um vetor de inicialização (IV) que introduz aleatoriedade e evita padrões repetitivos, o que o torna mais seguro que o modo ECB.

Correto.

6) Falso ☒

Justificação correta: Chaves maiores aumentam a complexidade de um ataque de força bruta, não facilitam.

Correto.

Perguntas de Desenvolvimento Teórico (4 questões):

1) Explique o funcionamento da estrutura de Feistel usada no DES.

2) Detalhe os passos envolvidos na cifragem e explique como a chave é utilizada em cada iteração.

Descreva o protocolo Diffie-Hellman.

3) Como duas partes podem gerar uma chave secreta compartilhada utilizando este protocolo? Quais são as principais limitações?

Explique o conceito de assinatura digital.

4) Descreva como é gerada e verificada uma assinatura digital e a importância dela na segurança da informação.

Compare o AES (Advanced Encryption Standard) com o DES (Data Encryption Standard).

Cite as principais diferenças entre os dois algoritmos em termos de segurança, tamanho de chave e eficiência.

Correção das Perguntas de Desenvolvimento:

1. Estrutura de Feistel

Sua resposta:

"A estrutura de Feistel inclui substituição e permutação, que são baseadas nas propriedades de difusão e confusão. A substituição é substituir um bit ou grupos de bits do plaintext pelo texto cifrado e a permutação é a troca de segmentos de bits do plaintext por segmentos do texto cifrado, não adicionando e tirando."

Correção:

A explicação de substituição e permutação está parcialmente correta, mas a definição foi confusa.

A estrutura de Feistel divide o texto claro em duas metades (L e R) e, em cada rodada:

A metade R é processada com uma função de chave (F) e combinada com a metade L usando uma operação XOR.

Depois, as metades são trocadas.

A substituição ocorre dentro da função F, enquanto a permutação é realizada no processo de troca das metades.

Nota: 2.5/4 pontos. A resposta foi superficial e faltou detalhamento técnico.

2. Protocolo Diffie-Hellman

Sua resposta:

"BOB e ALICE escolhem um número primo p e uma base g conhecida pelos dois. De seguida, ambos escolhem um valor x e y entre 1 e p e enviam $g^x \bmod p$ e $g^y \bmod p$ um para o outro. Ao

igualarem as expressões, obtêm um valor k que é a chave. A limitação é que qualquer algoritmo assíncrono é vulnerável a ataques man-in-the-middle."

Correção:

A explicação inicial está correta e bem estruturada.

Porém, a conclusão "ao igualarem as expressões" não é clara. O valor compartilhado k é obtido independentemente.

A limitação foi bem apontada: o protocolo não fornece autenticação, o que o torna vulnerável a man-in-the-middle.

Nota: 3.5/4 pontos. Resposta boa, mas faltou clareza na obtenção final de

k

k .

3. Assinatura Digital

Sua resposta:

"A assinatura digital serve para assinar mensagens e certificados. Geramos através do RSA um par de chaves (públicas e privadas) e usamos a chave privada para assinar digitalmente mensagens, garantindo autenticidade. Quem verifica as assinaturas digitais é uma autoridade certificadora."

Correção:

A explicação está correta, mas incompleta.

O processo de assinatura digital envolve:

A mensagem é hashada (função hash).

O hash é assinado usando a chave privada do remetente.

A chave pública verifica a assinatura e a integridade da mensagem.

A autoridade certificadora (CA) não verifica mensagens individuais; ela emite certificados digitais que vinculam uma chave pública à identidade do proprietário.

Nota: 2.5/4 pontos. Resposta correta, mas faltaram detalhes técnicos e o papel correto da CA.

4. AES vs DES

Sua resposta:

"Ambos os algoritmos apresentam criptografia simétrica. O AES pode usar muitos modos, tal como o GCM, garantindo não só a confidencialidade, mas também a integridade, sendo mais flexível que o DES e mais seguro."

Correção:

A comparação foi vaga. Poderia ser mais técnica:

Tamanho de chave: DES usa chave de 56 bits, AES suporta 128, 192 e 256 bits.

Segurança: DES é vulnerável a ataques de força bruta devido ao tamanho pequeno da chave.

Estrutura: DES usa a estrutura de Feistel, enquanto AES usa uma rede de substituição-permutação (SPN).

Modos: AES suporta múltiplos modos (GCM, CBC, etc.), como mencionado.

Nota: 2/4 pontos. Resposta genérica e incompleta.

Perguntas de Verdadeiro ou Falso:

Verdadeiro ou Falso:

- 1) O CVSS (Common Vulnerability Scoring System) é uma métrica utilizada para medir a severidade de uma vulnerabilidade, considerando apenas os impactos locais e não os remotos.

Verdadeiro ou Falso:

- 2) O modelo STRIDE ajuda a identificar ameaças de segurança, sendo as categorias principais: Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service e Elevation of Privilege.

Verdadeiro ou Falso:

- 3) A cifra de Feistel é uma estrutura utilizada apenas em criptografia assimétrica.

Verdadeiro ou Falso:

- 4) AES (Advanced Encryption Standard) no modo ECB (Electronic Codebook) é considerado seguro para uso em grandes volumes de dados devido ao seu comportamento não determinístico.

Verdadeiro ou Falso:

- 5) As funções hash criptográficas devem ser resistentes à colisão, ou seja, não devem existir duas entradas diferentes que gerem o mesmo valor de hash.

Verdadeiro ou Falso:

- 6) O protocolo Diffie-Hellman permite o compartilhamento seguro de uma chave criptográfica em um canal inseguro, mas não fornece autenticação entre as partes.

Correção das Perguntas de Verdadeiro ou Falso

- 1) Falso ☒

Justificação correta: O CVSS mede a severidade de vulnerabilidades considerando diversos fatores, incluindo o impacto remoto e local.

2) Verdadeiro ☒

Justificação correta: O STRIDE abrange as seis categorias citadas (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service e Elevation of Privilege).

3) Falso ☒

Observação: A cifra de Feistel é utilizada em criptografia simétrica, não assimétrica.

4) Falso ☒

Justificação correta: O modo ECB do AES é inseguro para grandes volumes de dados porque blocos idênticos de plaintext resultam em blocos idênticos de ciphertext.

5) Verdadeiro ☒

Justificação correta: Funções hash devem ser resistentes à colisão para garantir integridade e segurança.

6) Verdadeiro ☒

Justificação correta: O protocolo Diffie-Hellman permite o compartilhamento seguro de chaves, mas não garante autenticação entre as partes.

Perguntas de Desenvolvimento Teórico:

- 1) Explique os conceitos de difusão e confusão em criptografia.
Como esses conceitos são aplicados na prática em algoritmos como DES e AES?
- 2) Descreva o funcionamento do algoritmo RSA.
Explique o processo de geração de chaves, criptografia e decifração de uma mensagem usando RSA.
Compare os ataques de pré-imagem e colisão em funções hash.
- 3) Cite um exemplo prático de função hash vulnerável a ataques de colisão.
Explique o que é o DSS (Digital Signature Standard) e como ele utiliza o algoritmo de curva elíptica (ECDSA).
- 4) Quais as vantagens de utilizar curvas elípticas em comparação ao RSA para assinaturas digitais?

Correção das Perguntas de Desenvolvimento

Difusão e Confusão

Sua resposta:

"A confusão oculta a relação entre a chave criptográfica e o texto cifrado. A difusão espalha os bits do plaintext pelo texto cifrado para reduzir ataques padrão e tornar o ataque mais difícil. Algoritmos como DES e AES são fundamentais em estruturas com muitas cifras por blocos e têm como objetivo garantir estas duas propriedades."

Correção:

Resposta bem estruturada, mas faltou mencionar que a difusão é implementada em AES e DES por meio de permutação e operações em blocos, enquanto a confusão é garantida pelo uso de substituições (S-boxes). Poderia ser mais detalhado em relação ao funcionamento interno dos algoritmos.

Nota: 3.5/4 pontos.

Funcionamento do RSA

Sua resposta:

"O RSA gera um par de chaves para cada entidade, uma delas pública e conhecida por todos e outra é privada e mantida em segredo. A geração das chaves é com base num algoritmo de pseudoaleatoriedade. Usamos a chave pública de uma entidade para garantir que só ela consegue aceder à mensagem e a chave privada para autenticar a mesma mensagem, garantindo assim a autenticidade, onde a entidade que recebe a mensagem decifra usando a chave privada dela e a chave pública para garantir quem envia a mensagem."

Correção:

A resposta contém confusão no uso das chaves. O correto é:

Criptografia: A chave pública é usada para cifrar a mensagem e somente a chave privada correspondente pode decifrá-la.

Assinatura digital: A chave privada é usada para assinar a mensagem e a chave pública verifica a assinatura.

Além disso, a geração de chaves no RSA é baseada em números primos grandes e no produto deles, não em pseudoaleatoriedade pura.

Nota: 2/4 pontos.

Pré-imagem vs Colisão em Funções Hash

Sua resposta:

"O ataque de pré-imagem é a descoberta de um x tal que $H(x)=h$, e o ataque de colisão é encontrar um $x \neq y$ tal que $H(x)=H(y)$."

Correção:

Resposta correta e clara, mas poderia dar um exemplo prático de função hash vulnerável, como MD5 ou SHA-1. Além disso, a pré-imagem é mais difícil que a colisão em termos de complexidade computacional.

Nota: 3.5/4 pontos.

Curvas Elípticas e DSS

Sua resposta:

"A curva elíptica serve maioritariamente para a partilha de chaves entre entidades, onde o certificado com assinatura digital garante a autenticidade de ambas as partes envolvidas, a vantagem de usar curvas elípticas ao invés de RSA é porque as curvas elípticas são mais especificadas para a troca, como dito antes, pelo que é mais eficiente."

Correção:

A resposta está incompleta e confusa.

O uso de curvas elípticas é mais eficiente porque permite segurança equivalente com chaves menores comparadas ao RSA.

DSS (Digital Signature Standard) utiliza ECDSA (Elliptic Curve Digital Signature Algorithm) para assinatura digital, garantindo autenticidade, integridade e não repúdio.

A resposta deveria explicar mais claramente as vantagens e o uso em comparação ao RSA.

Nota: 2/4 pontos.